Temat: Od Dockera do Kubernetesa · dzień 4: bezpieczeństwo, sieć, rozszerzanie API

Termin: 5 dni, 9:00–17:00

Prowadzi: Dawid Marniok

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Dzień 4

Bezpieczeństwo · sieć · rozszerzanie API

sages

Wczoraj: stan, zadania, zasoby, planowanie

1 **Storage**

PVC wisi w Pending. Co sprawdzasz najpierw?

2 **Job / CronJob**

Czym różni się restartPolicy w Jobie od Deploymentu?

3 **Zasoby i QoS**

Pod ma requests = limits. Jaka to klasa QoS?

4 **Planowanie**

Taint NoSchedule na węźle. Co musi mieć pod?

Odpowiedzi na czat: numer pytania i jedno zdanie

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Dzień 4: od uprawnień do własnych typów w API



kto może wołać API → co może pod → kto z kim w sieci → nowe typy w API

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

TERAZ · Na start

Sprawdź, kim jesteś dla klastra

```
kubectl config current-context
kubectl auth whoami                          # kim jestem dla API
kubectl auth can-i create pods -n <login>
kubectl auth can-i create pods -n kube-system
kubectl auth can-i --list -n <login> | head -15
```

NA CZAT wynik kubectl auth whoami · i dwa wyniki can-i (yes/no)

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

DZIEŃ 4 · TEMAT 1

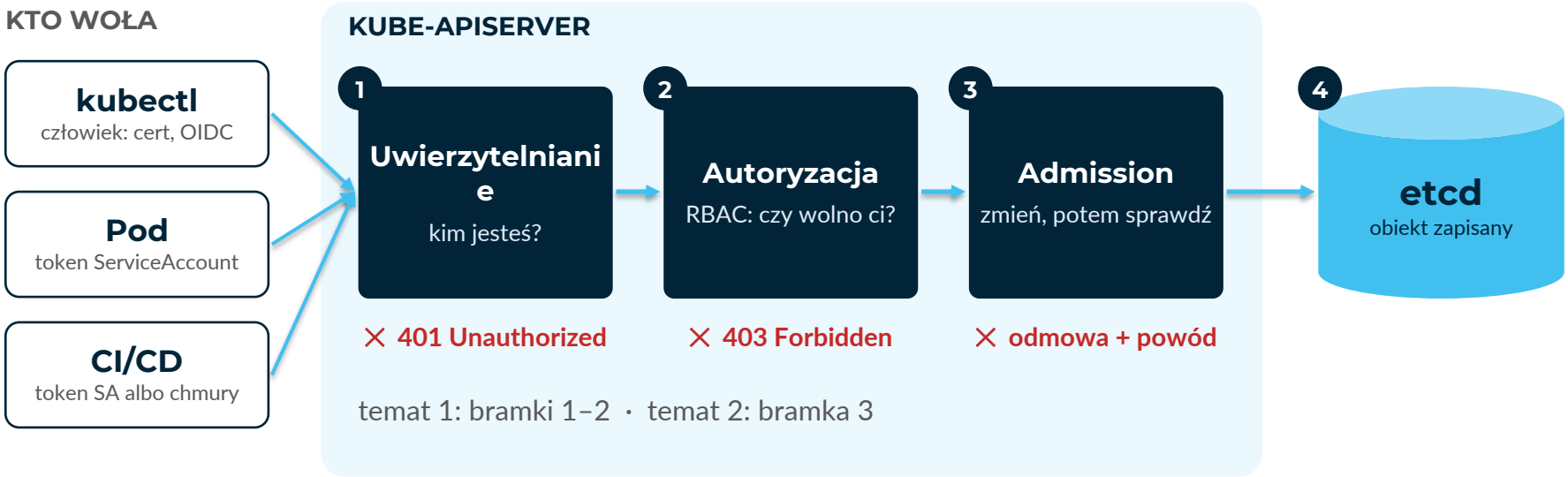
1 RBAC i ServiceAccount

Po tym temacie wiesz, kto może co w klastrze, i dajesz aplikacji tylko te uprawnienia, których potrzebuje.

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Każde żądanie przechodzi trzy bramki przed etcd



Odmowa na bramce 1 to 401, na bramce 2 i 3 to 403 z powodem w treści błędu

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Kubernetes nie ma kont, tylko sprawdza dowód

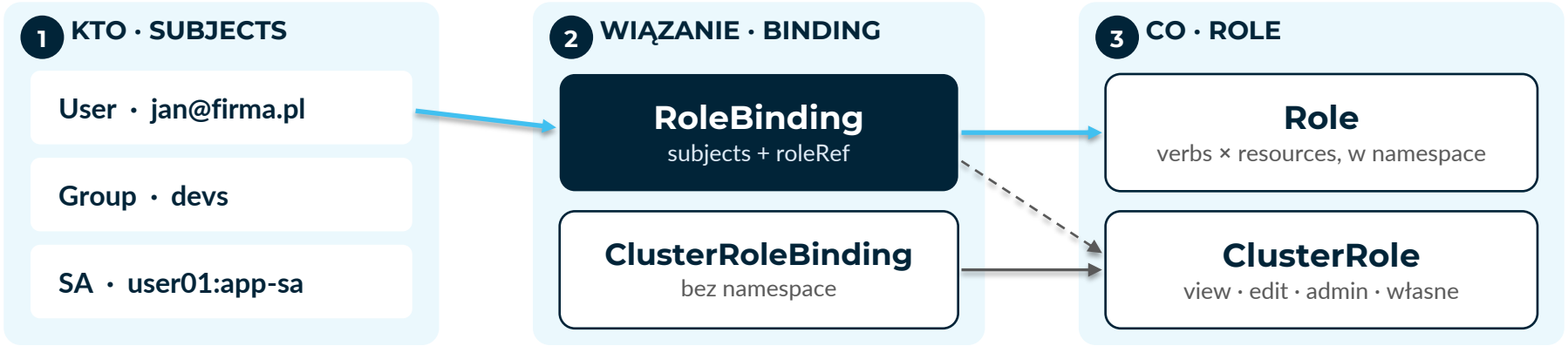
Mechanizm	Kto używa	Na co uważać
Certyfikat x509	admin, kubeadm, kind	nie odwołasz przed wygaśnięciem
Token ServiceAccount	pody, CI w klastrze	krótki, związany z podem
OIDC przez plugin exec	ludzie: Entra ID, Okta	kubelogin, nie auth-provider
Token chmury	EKS, GKE: IAM	aws eks get-token w exec

401 Unauthorized
nie wiem, kim jesteś: zły lub wygasły dowód

403 Forbidden
wiem, kim jesteś, ale nie wolno ci

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

RBAC to trzy pytania: kto, co, gdzie



4 GDZIE · ZASIĘG

Role + RoleBinding	ClusterRole + RoleBinding	ClusterRole + ClusterRoleBinding
jeden namespace	jeden namespace, rola wspólna	cały klaster

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Role i RoleBinding: minimum w namespace

```yaml
apiVersion: rbac.authorization.k8s.io/v1
kind: Role
metadata:
  name: pod-reader
rules:
- apiGroups: [""]  # grupa core
  resources: ["pods", "pods/log"]
  verbs: ["get", "list", "watch"]
```

```yaml
apiVersion: rbac.authorization.k8s.io/v1
kind: RoleBinding
metadata:
  name: read-pods
subjects:
- kind: ServiceAccount
  name: pod-reader-sa
  namespace: user01
roleRef:
  kind: Role
  name: pod-reader
  apiGroup: rbac.authorization.k8s.io
```

Szybciej: kubectl create role ... --verb=get,list --resource=pods --dry-run=client -o yaml

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Sprawdzaj, nie zgaduj: kubectl auth can-i

```
kubectl auth can-i create deployments -n user01
kubectl auth can-i --list -n user01

SA=system:serviceaccount:user01:pod-reader-sa
kubectl auth can-i list pods      -n user01 --as=$SA   # yes
kubectl auth can-i delete pods    -n user01 --as=$SA   # no
kubectl auth can-i get secrets    -n user01 --as=$SA   # no
```

--as
wymaga uprawnienia impersonate

--list
wszystkie moje reguły w namespace

403 w logach
user + verb + zasób = gotowa reguła

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

ServiceAccount to tożsamość poda, nie człowieka

```yaml
apiVersion: v1
kind: ServiceAccount
metadata:
  name: app-sa
automountServiceAccountToken: false
---
# fragment Poda / Deploymentu
spec:
  serviceAccountName: app-sa
  automountServiceAccountToken: true
```

Token projected
ważny ~1 h, kubelet go odnawia, ginie z podem

Brak auto-Secretu
od 1.24 SA nie dostaje Secretu z tokenem

Token na żądanie
kubectl create token app-sa --duration=10m

Domyślny SA
default w każdym ns: nie dawaj mu ról

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Własny ServiceAccount: co zyskujesz i kiedy

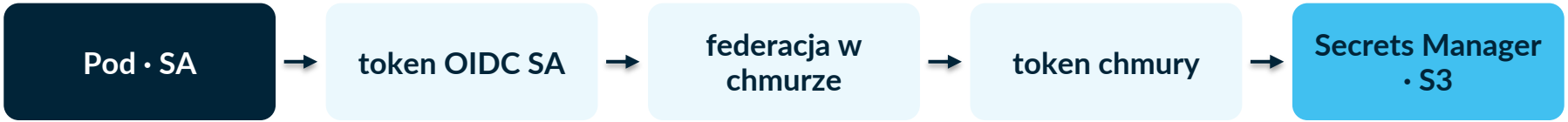
Sytuacja	Co robisz z SA	Co to daje
Aplikacja nie woła API (ToDos api, web)	własny SA, automount: false	po włamaniu do poda brak tokenu
Aplikacja woła API (Prometheus, CI)	Role z konkretnymi verbs dla tego SA	tylko jej uprawnienia, reszta 403
Aplikacja woła AWS (S3, Secrets Manager)	Pod Identity na ten SA	api czyta swój bucket, web nic
Audyt i incydent	osobny SA na aplikację	w logu: system:serviceaccount:user01:api

Sam SA nic nie daje. Liczy się, co do niego przypniesz, a czego nie przypniesz do default

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Do chmury bez kluczy: workload identity



Chmura	Mechanizm	Co wiążesz z ServiceAccountem
EKS ← nasz	Pod Identity · IRSA	asocjacja w EKS · adnotacja role-arn
AKS	Workload Identity	adnotacja client-id + etykieta use: "true"
GKE	Workload Identity Federation	principal SA w IAM

Zero sekretów w YAML: klucz do chmury nie leży w Secrecie, token żyje godzinę

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

cluster-admin dla aplikacji to klucz do klastra

```
apiVersion: rbac.authorization.k8s.io/v1
kind: ClusterRoleBinding
metadata:
  name: app-admin   # „bo nie działało”
subjects:
- kind: ServiceAccount
  name: app-sa
  namespace: user01
roleRef:
  kind: ClusterRole
  name: cluster-admin
  apiGroup: rbac.authorization.k8s.io
```

WŁAMANIE DO PODA = WŁAMANIE DO KLASTRA

- czyta wszystkie Secrety we wszystkich ns
- tworzy pod privileged z hostPath: /
- dopisuje sobie kolejne bindingi

Zamiast tego

własny SA, Role z konkretnymi verbs, RoleBinding w jednym ns

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

▶ DEMO · RBAC krok po kroku

Od 403 do yes bez restartu

Cel: pusty ServiceAccount → pod pyta API → Role → RoleBinding → can-i

OBSERWUJCIE

1. komunikat 403: kto, verb, zasób
2. po bindingu ten sam pod dostaje listę
3. delete dalej no: minimum

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

LAB `labs/lab13-rbac/`

RBAC i ServiceAccount w Twoim namespace

1. Role pod-reader + RoleBinding dla pod-reader-sa
2. deployment-manager dla deploy-sa, sprawdź can-i
3. własny SA w podzie, token montowany albo nie
4. pod z kubectl pyta API jako pod-reader-sa

SUKCES can-i list pods → yes, delete pods → no dla pod-reader-sa

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Komu w Waszym klastrze zabralibyście uprawnienia?

Następny temat: Pod Security i admission

Bramka 3: czego pod nie może zrobić, nawet gdy RBAC go wpuścił

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

2

DZIEŃ 4 · TEMAT 2

Pod Security i admission

Po tym temacie uruchamiasz pod bez roota i bez zbędnych uprawnień, a klaster pilnuje tego za Ciebie.

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Domyślnie pod może prawie wszystko na węźle

privileged: true

dostęp do urządzeń węzła, praktycznie root na hoście

hostPath: /

system plików węzła, w nim tokeny innych podów

root w kontenerze

jedna luka w runtime dzieli go od węzła

```
spec:
  hostPID: true
  containers:
  - name: shell
    image: busybox:1.37
    securityContext:
      privileged: true
```

Wystarczy create pods

RBAC nie patrzy, co jest w środku poda. Ten YAML przejdzie bez słowa.

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Admission: najpierw zmień, potem sprawdź

BRAMKA 3 Z PORANNEGO DIAGRAMU, PO KOLEI



Wbudowany kontroler	Gdzie już go spotkaliście
LimitRanger · mutating	pod bez resources dostał requests i limits (dzień 3)
ResourceQuota · validating	exceeded quota przy skalowaniu (dzień 3)
PodSecurity · validating	violates PodSecurity: za chwilę, w demie

Mutating może obiekt poprawić, validating może go tylko odrzucić

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Mutating zmienia, Validating odrzuca

Mutating

dopisuje albo zmienia pola, zanim obiekt trafi do etcd

- LimitRanger: domyślne requests i limits
- EKS Pod Identity: zmienne AWS_* i token w podzie
- Istio: kontener proxy w każdym podzie
- Kyverno mutate: etykieta team, domyślne wartości

Validating

nic nie zmienia: przepuszcza albo odrzuca z powodem

- PodSecurity: root, privileged, hostPath
- ResourceQuota: przekroczony limit namespace
- VAP: zakaz :latest, wymagane limits
- Kyverno validate, Gatekeeper

JAK DOPISAĆ WŁASNĄ REGUŁĘ

Webhook
własna usługa HTTPS, zwykle Go

Polityka CEL
ValidatingAdmissionPolicy, wbudowana

Silnik polityk
Kyverno albo Gatekeeper

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Pod Security: trzy poziomy, jedna etykieta

privileged
bez ograniczeń: CNI, CSI, agenci

baseline
blokuje privileged, hostPath, hostNetwork

restricted
do tego non-root, drop ALL, seccomp

```
kubectl label ns user01 \
  pod-security.kubernetes.io/enforce=baseline \
  pod-security.kubernetes.io/warn=restricted \
  pod-security.kubernetes.io/audit=restricted
```

enforce: odrzuca · warn: ostrzeżenie w kubectl · audit: wpis w audit logu

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

securityContext, który przejdzie restricted

```
spec:
  securityContext:
    runAsNonRoot: true
    runAsUser: 101
    seccompProfile:
      type: RuntimeDefault
  containers:
  - name: web
    image: nginxinc/nginx-unprivileged:1.29
    securityContext:
      allowPrivilegeEscalation: false
      readOnlyRootFilesystem: true
      capabilities:
        drop: ["ALL"]
```

runAsNonRoot
kubelet nie wystartuje procesu z UID 0

allowPrivilegeEscalation
setuid i sudo nie podniosą uprawnień

drop: ALL
zero capabilities, dodajesz tylko potrzebne

RuntimeDefault
seccomp odcina rzadkie, groźne syscalle

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

securityContext: pod i kontener

```
kind: Deployment
spec:
  template:
    spec:
      securityContext:        # poziom poda
        runAsNonRoot: true
        runAsUser: 10001
        fsGroup: 10001        # tylko pod
        seccompProfile: {type: RuntimeDefault}
      containers:
      - name: app
        securityContext:      # tylko ten kontener
          readOnlyRootFilesystem: true
          capabilities: {drop: ["ALL"]}
      - name: log-agent
        securityContext:
          runAsUser: 65534    # nadpisuje pod
```

Tylko pod
fsGroup, supplementalGroups, sysctls: wspólne wolumeny i sieć

Oba poziomy
runAsUser, runAsGroup, runAsNonRoot, seccomp, AppArmor, SELinux: kontener wygrywa

Tylko kontener
capabilities, privileged, allowPrivilegeEscalation, readOnlyRootFilesystem

Deployment nie ma własnego securityContext: to pod z spec.template.spec

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Obraz z rootem + runAsNonRoot = błąd startu

Obraz
USER root albo brak USER · albo USER node (nazwa)

→

Manifest
runAsNonRoot: true, bez runAsUser

→

Kubelet przed startem
nie umie potwierdzić, że to nie root: STOP

```
web   0/1   CreateContainerConfigError      # kubectl get pod: kontener nie wystartował
Error: container has runAsNonRoot and image will run as root
Error: container has runAsNonRoot and image has non-numeric user (node), cannot verify user is non-root
```

USER 10001 w Dockerfile
liczba, nie nazwa: najlepsza opcja

runAsUser w manifeście
UID z obrazu, np. node = 1000

obraz *-unprivileged
gotowe warianty: nginx, wiele baz i proxy

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Własne reguły: VAP, Kyverno czy Gatekeeper

Trzy sposoby na reguły, których PSA nie ma. Różnią się językiem i tym, co umieją poza „nie”.

	ValidatingAdmissionPolicy	Kyverno	OPA Gatekeeper
Język	CEL	YAML, CEL	Rego
Instalacja	nic: wbudowane w API	Helm: operator + webhook	Helm: operator + webhook
Umie	tylko odrzucić	odrzucić, zmienić, utworzyć, sprawdzić podpis	odrzucić, zmienić, audyt
Dla kogo	proste reguły na start	zespoły K8s, polityki w YAML	firmy z OPA poza K8s

Zacznij od PSA i VAP. Kyverno, gdy potrzebujesz mutacji, generowania albo podpisów obrazów

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Prawdziwe reguły: problem → narzędzie

Reguła w firmie	Czym	Dlaczego tym
każdy Deployment ma limits	VAP	sprawdzenie pól, zero instalacji
obrazy tylko z naszego ECR	VAP albo Kyverno	prefiks w polu image
zakaz externalIPs w Service	VAP	luka w Service, następny slajd
etykieta team dopisana sama	Kyverno mutate	zmiana obiektu, VAP tego nie umie
podpis cosign na obrazie	Kyverno verifyImages	pyta rejestr o podpis
nowy ns od razu z default-deny	Kyverno generate	tworzy obiekt, nie tylko sprawdza

Reguła tylko „tak/nie” na polach obiektu → VAP. Wszystko ponad to → Kyverno

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

externalIPs: Service, który przechwytuje cudzy ruch

Pod aplikacji
łączy się z 8.8.8.8:53 (DNS Google)

↓

kube-proxy na węźle
8.8.8.8 jest w externalIPs czyjegoś Service

↓

Pod atakującego
dostaje ruch zamiast 8.8.8.8

CVE-2020-8554: wystarczy create services. Łatki nie ma

```yaml
apiVersion: admissionregistration.k8s.io/v1
kind: ValidatingAdmissionPolicy
metadata:
  name: zakaz-external-ips
spec:
  failurePolicy: Fail
  matchConstraints:
    resourceRules:
    - apiGroups: [""]
      apiVersions: ["v1"]
      operations: ["CREATE", "UPDATE"]
      resources: ["services"]
  validations:
  - expression: "!has(object.spec.externalIPs)"
    message: "externalIPs są zabronione"
# + ValidatingAdmissionPolicyBinding: Deny
```

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Skanuj przed wdrożeniem i w działającym klastrze

Narzędzie	Co sprawdza	Kiedy
`trivy image nginx:1.29`	CVE w pakietach obrazu	CI, przed push
`trivy config ./k8s`	YAML, Dockerfile, Helm, Terraform	pull request
`trivy image --format cyclonedx`	SBOM: CycloneDX albo SPDX	przy wydaniu
Trivy Operator	raporty jako obiekty w klastrze	ciągle
`kubescape scan`	NSA, MITRE, CIS: YAML i klaster	audyt
kube-bench	CIS Benchmark węzłów	po instalacji

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Secret to base64, nie szyfrowanie

```
$ kubectl get secret db -n user01 -o yaml | grep password
  password: c3VwZXJ0YWpuZQ==
$ echo c3VwZXJ0YWpuZQ== | base64 -d
supertajne
```

Szyfrowanie w etcd

EncryptionConfiguration albo KMS; w chmurze klucz z KMS

RBAC na secrets

get, list, watch = odczyt haseł; rola view ich nie ma

Sejf poza klastrem

External Secrets Operator, CSI Secrets Store, Vault

Kto może utworzyć pod w namespace, ten zamontuje każdy Secret z tego namespace

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

▶ DEMO · Pod Security Admission

Najpierw warn, potem enforce

Cel: ten sam pod przy trzech ustawieniach namespace

OBSERWUJCIE

1. ostrzeżenia już przy apply
2. Deployment jest, podów brak
3. poprawiony pod przechodzi

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

LAB `labs/lab14-skanowanie/`

Skanowanie obrazów i manifestów

1. trivy image: nginx:1.29 vs 1.29-alpine, z --ignore-unfixed
2. SBOM: trivy image --format cyclonedx, potem trivy sbom
3. trivy config i kubescape na do-skanu/web.yaml
4. popraw manifest do restricted i wgraj go

SUKCES liczby CVE dla dwóch obrazów i manifest bez błędów securityContext

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Który Wasz obraz nie przeszedłby restricted?

Następny temat: Sieć: CNI, NetworkPolicy, DNS

Pod jest bezpieczny w środku. Teraz: z kim może rozmawiać

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

3

DZIEŃ 4 · TEMAT 3

Sieć: CNI, NetworkPolicy, DNS

Po tym temacie zamykasz ruch między podami do niezbędnego minimum i wiesz, jak pod znajduje usługę po nazwie.

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Płaska sieć: każdy pod widzi każdego

- każdy pod ma własny adres IP
- pod ↔ pod bez NAT, także między węzłami
- Service: stały adres przed podami (dzień 2)
- domyślnie brak firewalla między podami

CNI	Co go wyróżnia
Calico	BGP lub VXLAN, NetworkPolicy, on-prem
Cilium	eBPF, polityki L7, podgląd ruchu w Hubble
VPC CNI ← nasz	IP z VPC; polityki przez eBPF (EKS)
Flannel	prosty overlay, nie wspiera NetworkPolicy
kindnet	domyślny w kind, podstawowe polityki

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

NetworkPolicy: firewall dla podów

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: backend
spec:
  podSelector: …      # KOGO chronię
  policyTypes: [Ingress, Egress]
  ingress:            # KTO może do mnie
  - from: …
    ports: …
  egress:             # DOKĄD mogę ja
  - to: …
```

Wybiera pody etykietami
działa w swoim namespace, jak Service

Tylko reguły allow
ingress: kto do mnie, egress: dokąd ja

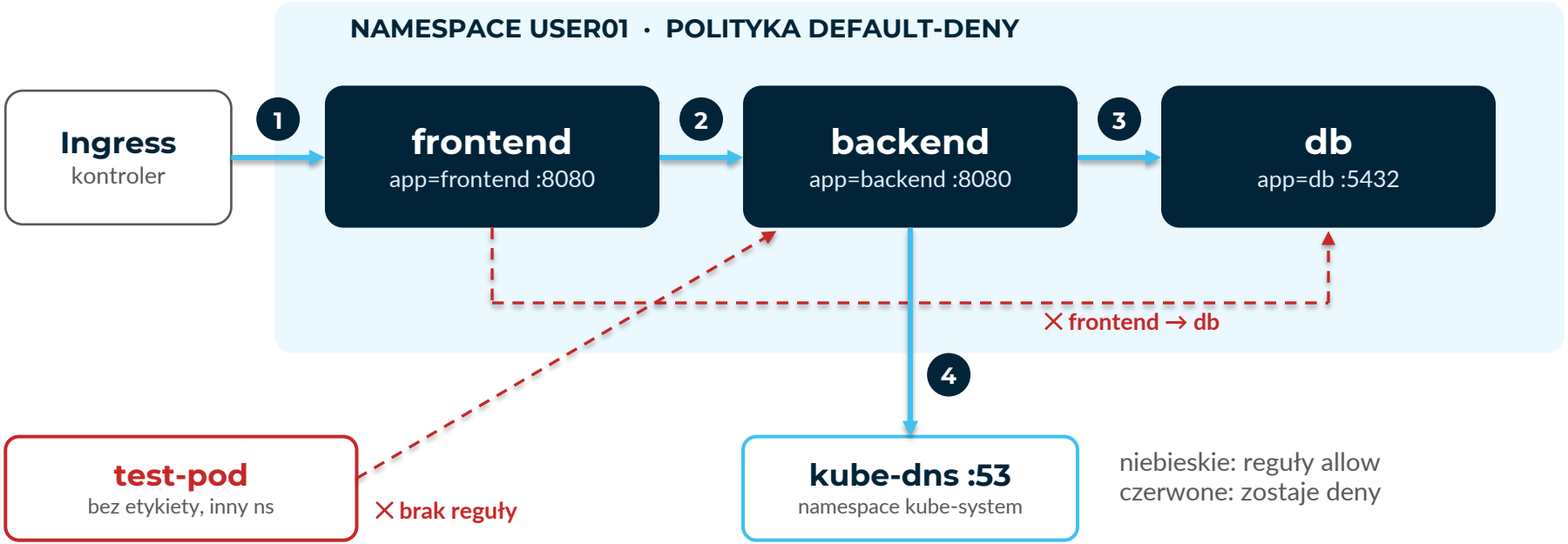
Pod objęty polityką
w tym kierunku wszystko inne zablokowane

Egzekwuje CNI
IP i porty (L3/L4), nie ścieżki HTTP

Pod bez żadnej polityki: wszystko otwarte. Pod z polityką: tylko to, co wpisane

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

Najpierw deny-all, potem tylko potrzebne strzałki



Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Pusty podSelector = cały namespace

1 · DEFAULT DENY

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: default-deny
spec:
  podSelector: {}
  policyTypes:
  - Ingress
  - Egress
```

2 · FRONTEND → BACKEND

```
apiVersion: networking.k8s.io/v1
kind: NetworkPolicy
metadata:
  name: backend-from-frontend
spec:
  podSelector:
    matchLabels: {app: backend}
  policyTypes: ["Ingress"]
  ingress:
  - from:
    - podSelector:
        matchLabels: {app: frontend}
    ports:
    - port: 8080
```

Polityki tylko dodają wyjątki. Nie ma reguły deny, jest brak allow

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Egress: DNS i internet otwierasz jawnie

DNS · DO KUBE-DNS

```
egress:
- to:
  - namespaceSelector:
      matchLabels:
        kubernetes.io/metadata.name: kube-system
    podSelector:
      matchLabels:
        k8s-app: kube-dns
  ports:
  - port: 53
    protocol: UDP
  - port: 53
    protocol: TCP
```

INTERNET · HTTPS

```
- to:
  - ipBlock:
      cidr: 0.0.0.0/0
      except:
      - 10.0.0.0/8
      - 172.16.0.0/12
      - 192.168.0.0/16
  ports:
  - port: 443
    protocol: TCP
```

Pusty namespaceSelector
to wszystkie pody w klastrze, nie internet

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Jeden myślnik zmienia AND w OR

AND · JEDEN ELEMENT LISTY

```
- from:
  - namespaceSelector:
      matchLabels:
        team: monitoring
    podSelector:
      matchLabels:
        app: prometheus
```

Wchodzi tylko

pody app=prometheus z namespace'ów team=monitoring

OR · DWA ELEMENTY

```
- from:
  - namespaceSelector:
      matchLabels:
        team: monitoring
  - podSelector:
      matchLabels:
        app: prometheus
```

Wchodzi

WSZYSTKO z namespace'ów team=monitoring + pody app=prometheus z MOJEGO namespace

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

CoreDNS i ndots:5: skąd te dziwne zapytania

```
$ kubectl exec web -- cat /etc/resolv.conf
search user01.svc.cluster.local svc.cluster.local cluster.local
nameserver 172.20.0.10
options ndots:5
```

Zapytanie w podzie	Co się dzieje
backend	backend.user01.svc.cluster.local: Service w moim ns
backend.user02	Service w innym namespace
db-0.db	konkretny pod StatefulSetu (headless Service)
api.github.com	2 kropki < 5: najpierw 3 zbędne zapytania z search, potem właściwe

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

ExternalName: alias w DNS na usługę spoza klastra

```
apiVersion: v1
kind: Service
metadata:
  name: payments-db
spec:
  type: ExternalName
  externalName: db.prod.example.com
```

ExternalName = CNAME w DNS
bez proxy i portów; TLS widzi nazwę zewnętrzną

CO SIĘ DZIEJE PRZY POŁĄCZENIU

aplikacja: payments-db:5432
krótka nazwa, jak każdy Service

↓

CoreDNS: CNAME
payments-db.user01.svc → db.prod.example.com

↓

zwykły DNS
db.prod.example.com → adres bazy

Nie mylić z externalIPs: to luka z tematu 2

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

▶ DEMO · NetworkPolicy

deny-all, potem jedna strzałka naraz

Cel: frontend → backend → db: zamykamy namespace i otwieramy tylko potrzebne

OBSERWUJCIE

1. curl działa, potem timeout
2. DNS pada razem z deny-all
3. frontend → db zostaje zamknięte

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

LAB `labs/lab15-networkpolicy/`

NetworkPolicy w Twoim namespace

1. deny-all dla app=web, test z test-pod
2. frontend → backend, test z obu stron
3. egress: DNS, HTTPS przez ipBlock, HTTP w namespace
4. chętni w parach: ruch z ns sąsiada po metadata.name

SUKCES frontend → backend działa, test-pod dostaje timeout

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Który ruch w Waszym klastrze nie powinien istnieć?

Następny temat: Rozszerzanie API

CRD i Downward API: jak inne narzędzia dopisują się do Kubernetesa

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

DZIEŃ 4 · TEMAT 4

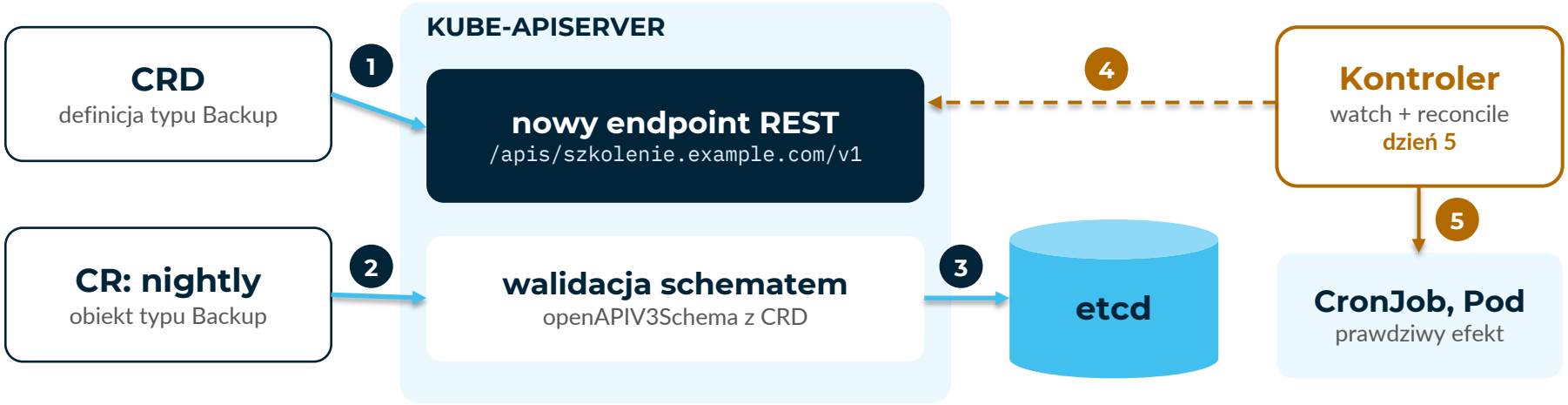
4 Rozszerzanie API

Po tym temacie wiesz, czym jest CRD, czego sam nie robi, i jak pod może poznać własne metadane.

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

CRD dodaje nowy typ, kontroler daje mu działanie



Bez kontrolera CR to tylko rekord w etcd: kubectl get działa, nic więcej się nie dzieje

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

CRD i pierwszy obiekt nowego typu

```yaml
apiVersion: apiextensions.k8s.io/v1
kind: CustomResourceDefinition
metadata:
  name: backups.szkolenie.example.com
spec:
  group: szkolenie.example.com
  scope: Namespaced
  names: {kind: Backup, plural: backups, shortNames: [bk]}
  versions:
  - name: v1
    served: true
    storage: true
    schema:
      openAPIV3Schema:
        type: object
        properties:
          spec:
            type: object
            properties:
              schedule: {type: string}
              retention: {type: integer, minimum: 1}
```

```yaml
apiVersion: szkolenie.example.com/v1
kind: Backup
metadata:
  name: nightly
spec:
  schedule: "0 2 * * *"
  retention: 7
```

```
kubectl get crd | grep szkolenie
kubectl get backups
kubectl get bk -o yaml
kubectl explain backup.spec
```

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

CRD znacie już z cert-managera i Gateway API

Projekt	Przykładowe CRD	Co robi kontroler
cert-manager	Certificate, Issuer, ClusterIssuer	wystawia i odnawia certyfikaty TLS
Gateway API	Gateway, HTTPRoute	konfiguruje ruch do Service (dzień 2)
Prometheus Operator	ServiceMonitor, PrometheusRule	konfiguruje Prometheusa (dzień 5)
Argo CD	Application, AppProject	synchronizuje klaster z Gitem
Kyverno	ClusterPolicy, PolicyReport	polityki admission (temat 2)
CloudNativePG	Cluster, Backup	PostgreSQL z replikami (dzień 5)

Instalujesz narzędzie = instalujesz CRD + kontroler. Helm robi to jednym poleceniem

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Downward API: pod wie, kim jest

ZMIENNE ŚRODOWISKOWE

```
env:
- name: POD_NAME
  valueFrom:
    fieldRef:
      fieldPath: metadata.name
- name: NODE_NAME
  valueFrom:
    fieldRef:
      fieldPath: spec.nodeName
- name: MEM_LIMIT
  valueFrom:
    resourceFieldRef:
      resource: limits.memory
```

WOLUMEN Z PLIKAMI

```
volumes:
- name: podinfo
  downwardAPI:
    items:
    - path: labels
      fieldRef:
        fieldPath: metadata.labels
    - path: annotations
      fieldRef:
        fieldPath: metadata.annotations
```

pliki odświeżają się, env nie zmienia się do restartu

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

▶ DEMO · CRD i Downward API

Własny typ w API w trzy minuty

Cel: CRD Backup, obiekt nightly, potem pod, który zna swoje metadane

OBSERWUJCIE

1. kubectl get bk bez wtyczek
2. walidacja odrzuca retention: 0
3. env i pliki z metadanymi

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

LAB labs/lab16-downward-api-crd/

Pod, który zna sam siebie

1. pod z env: POD_NAME, POD_NAMESPACE, POD_IP, MEMORY_LIMIT
2. kubectl logs pod-info: porównaj z get -o wide
3. wolumen downwardAPI z etykietami, zmień etykietę
4. obiekt Backup nightly u siebie, retention: 0

SUKCES pod zna nazwę, IP i limit; plik labels się zmienia; get bk → nightly

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Jaki własny typ przydałby się w Waszym klastrze?

Teraz: ToDos · dzień 4

ServiceAccount, Pod Security i NetworkPolicy na Waszej aplikacji; co nie zdążycie, kończymy jutro rano

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

LAB `labs/todos-dzien4/`

Twój ToDos bez roota i za firewallem

1. ServiceAccount dla api, web i mongo, bez tokenu
2. securityContext: bez roota, liczbowe UID, read-only
3. PSA warn/audit=restricted, enforce tylko dry-run
4. NetworkPolicy: Traefik → web → api → mongo

SUKCES ToDos działa z wczorajszymi zadaniami, dry-run enforce bez Warning, nptest zablokowany

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Dzień 4: trzy warstwy obrony i jedno rozszerzenie

Temat	Zapamiętaj	Komenda
RBAC i SA	własny SA, minimum uprawnień	`kubectl auth can-i --as=…`
Pod Security	baseline na enforce, non-root	`trivy image --severity HIGH`
Sieć	deny-all + DNS + wyjątki	`kubectl describe netpol`
Rozszerzanie API	CRD bez kontrolera nic nie robi	`kubectl get crd`

API → pod → sieć: każda warstwa łapie to, co przepuściła poprzednia

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.

sages

Jutro: Helm, operatory, monitoring, projekt

Helm →	Operatory →	Monitoring →	Projekt ToDos
paczki z CRD, RBAC i NetworkPolicy w jednym	kontroler, którego dziś brakowało przy CRD	Prometheus Operator: ServiceMonitor to CRD	wszystko z 5 dni na jednej aplikacji

Na jutro: zostaw w namespace porządek i miej działający kubectl oraz helm

Copyright (C) 2026 Sages sp. z o.o. Kopiowanie, przetwarzanie, rozpowszechnianie tych materiałów w całości lub w części jest zabronione.